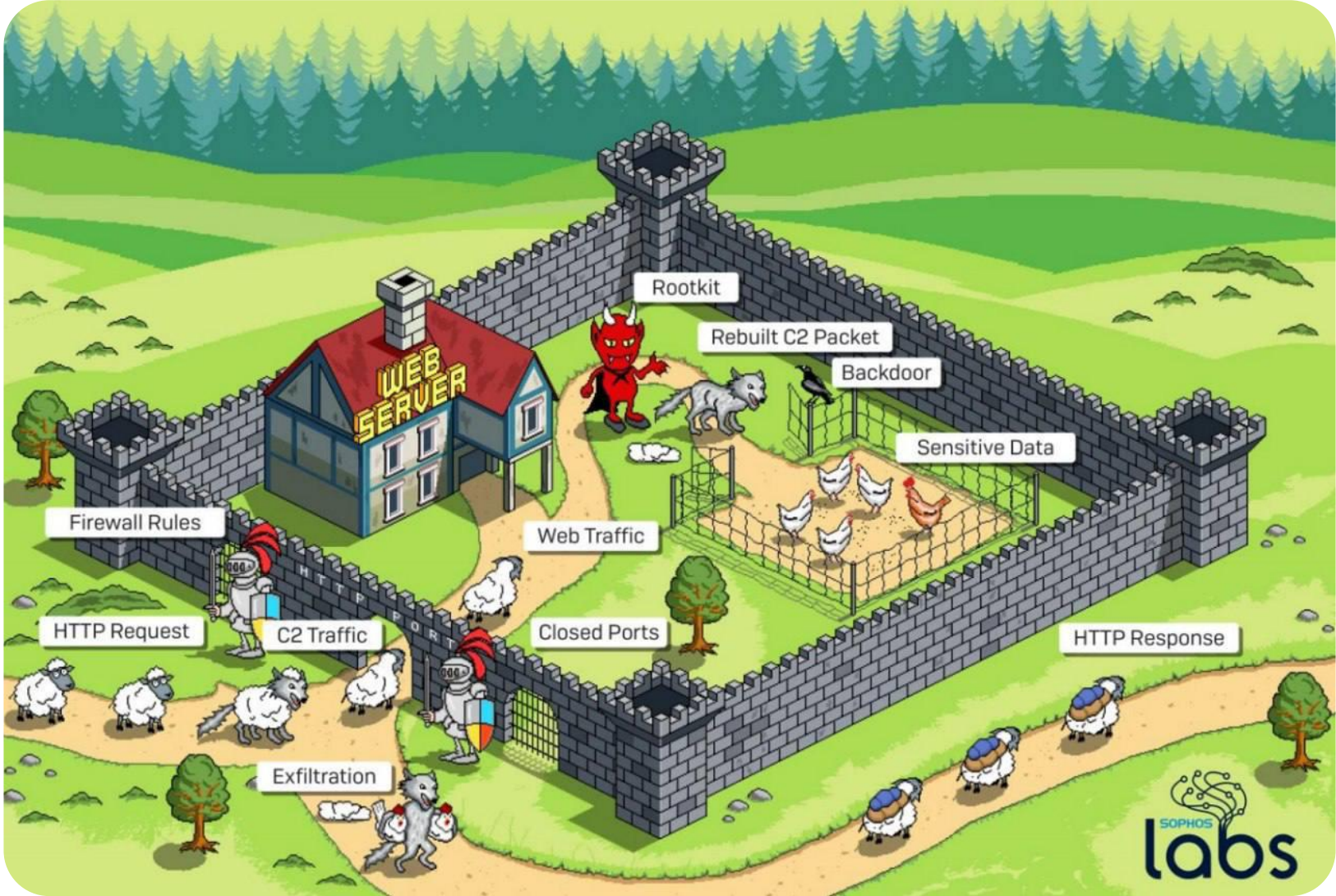


Security Hardening, или приведение системы к безопасным настройкам

Цель

Разобрать этапы настройки ОС для безопасного использования.

Для чего нужно проводить настройки безопасности?



Изображение: [Cloud Snooper attack](#)

Учётные записи

1. Не используйте root. Лучше использовать sudo
2. Настраивайте разграничение прав и привилегий
3. Настройте ограничение некоторым sudo пользователям к корневой оболочке
4. Ограничьте действия sudo пользователя с помощью команд через systemctl
5. Ограничьте вход учётным записям в чужие домашние каталоги
6. Применяйте политики надёжного пароля. Используйте pwquality и настройте критерии сложного пароля. Установите время жизни пароля
7. Временные УЗ должны иметь ограниченный срок жизни
8. Настройте блокировку учётной записи при нескольких неудачных попытках входа



Изображение: [Учётные записи](#)

Firewall

Настройте netfilter. Если через iptables, то необходимо настроить 2 брандмауэра, для IPv4 и IPv6.

Не забывайте перезагружать iptables после добавления правил. Iptables состоит из:

1. Таблицы фильтров (Filter table)
2. Таблицы NAT (NAT table)
3. Таблицы изменений (Mangle table)
4. Таблицы безопасности (Security table)

Также можно настраивать через утилиты ufw и firewalld в зависимости от предпочтений и используемых дистрибутивов.

Что настраиваем? Разрешаем и блокируем конкретные соединения с IP-адреса или на конкретный порт.

3 вида правил:

1. INPUT
2. FORWARD
3. OUTPUT

3 правила обработки трафика:

1. Accept
2. Drop
3. Reject

Настройка шифрования каналов и данных

Настройка SSH

Убедитесь, что протокол SSH 1 отключён.

Настройте подключение по сертификату:

- включите вход по SSH через обмен открытыми ключами
- отключите вход пользователя root через SSH
- отключите возможность подключения по логину/паролю

Настройка шифрования каналов и данных

Настройка SFTP

Настроить окружение chroot для SFTP.

Настройка шифрования каналов и данных

Настройка шифрования диска

Стандартом для шифрования жёсткого диска с Linux является LUKS. Расшифровать данные на диске можно, только имея доступ к секретному ключу и паролю.

Преимущество LUKS:

- совместимость через стандартизацию
- защита от атак с низкой энтропией
- возможность аннулирования секретной фразы
- распространяется бесплатно

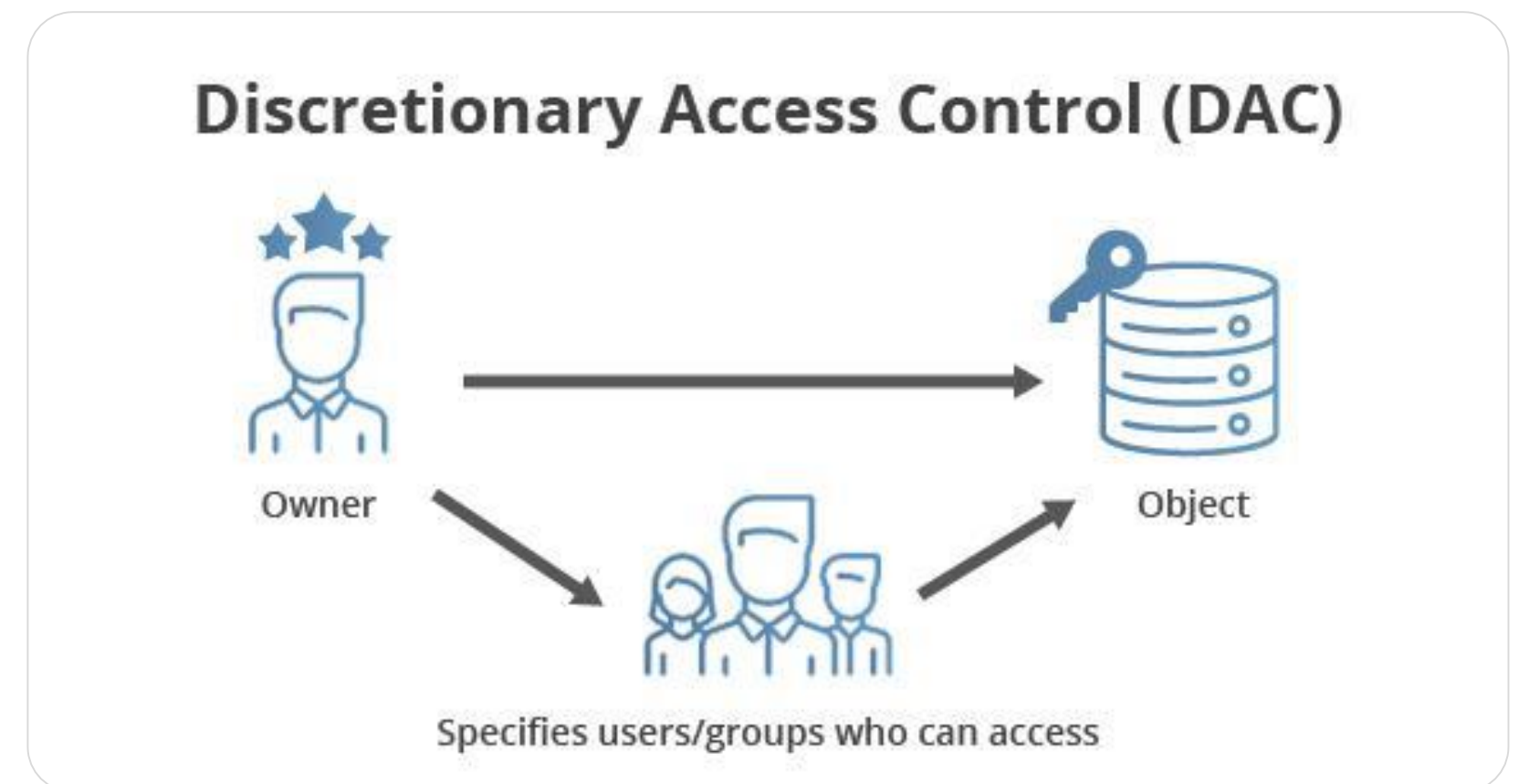
Ограничение доступа с помощью архитектуры Discretionary Access Control (DAC)

chown для смены владельца файлов и каталогов.

chmod для установки прав доступа к файлам и каталогам.

Настройте SUID и SGID. Можете запретить использование SUID и SGID на конкретный раздел.

Используйте расширенные атрибуты файлов для защиты конфиденциальных файлов.



Изображение: [Discretionary Access Control \(DAC\)](#)

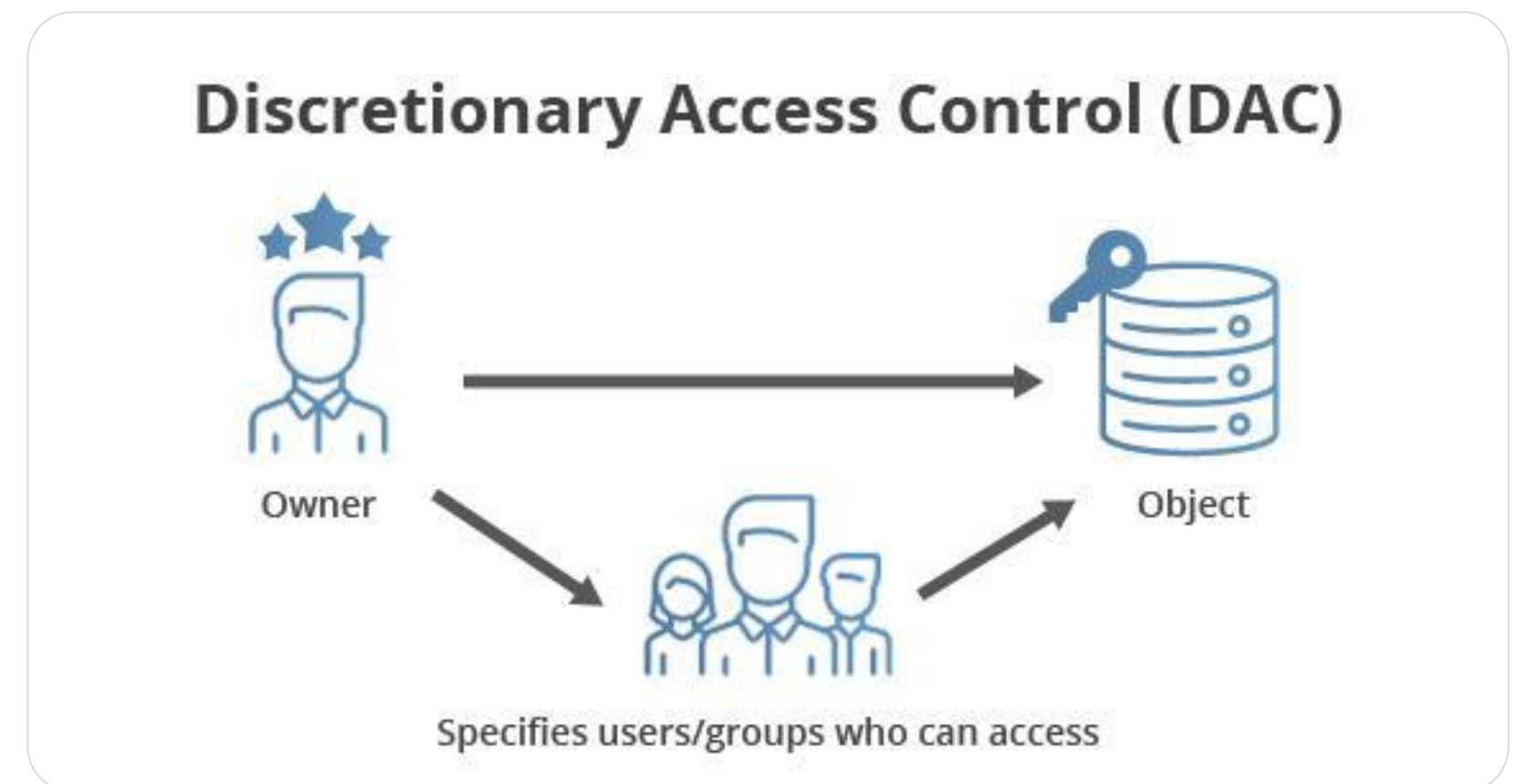
Ограничение доступа с помощью архитектуры Discretionary Access Control (DAC)

Запустите команду find для инвентаризации SUID и SGID.

```
sudo find / -type f \( -perm -4000 -o -perm 2000 \) > suid_sgid_files.txt
```

Периодически сверяйте данный файл с последующими выводами данной команды.

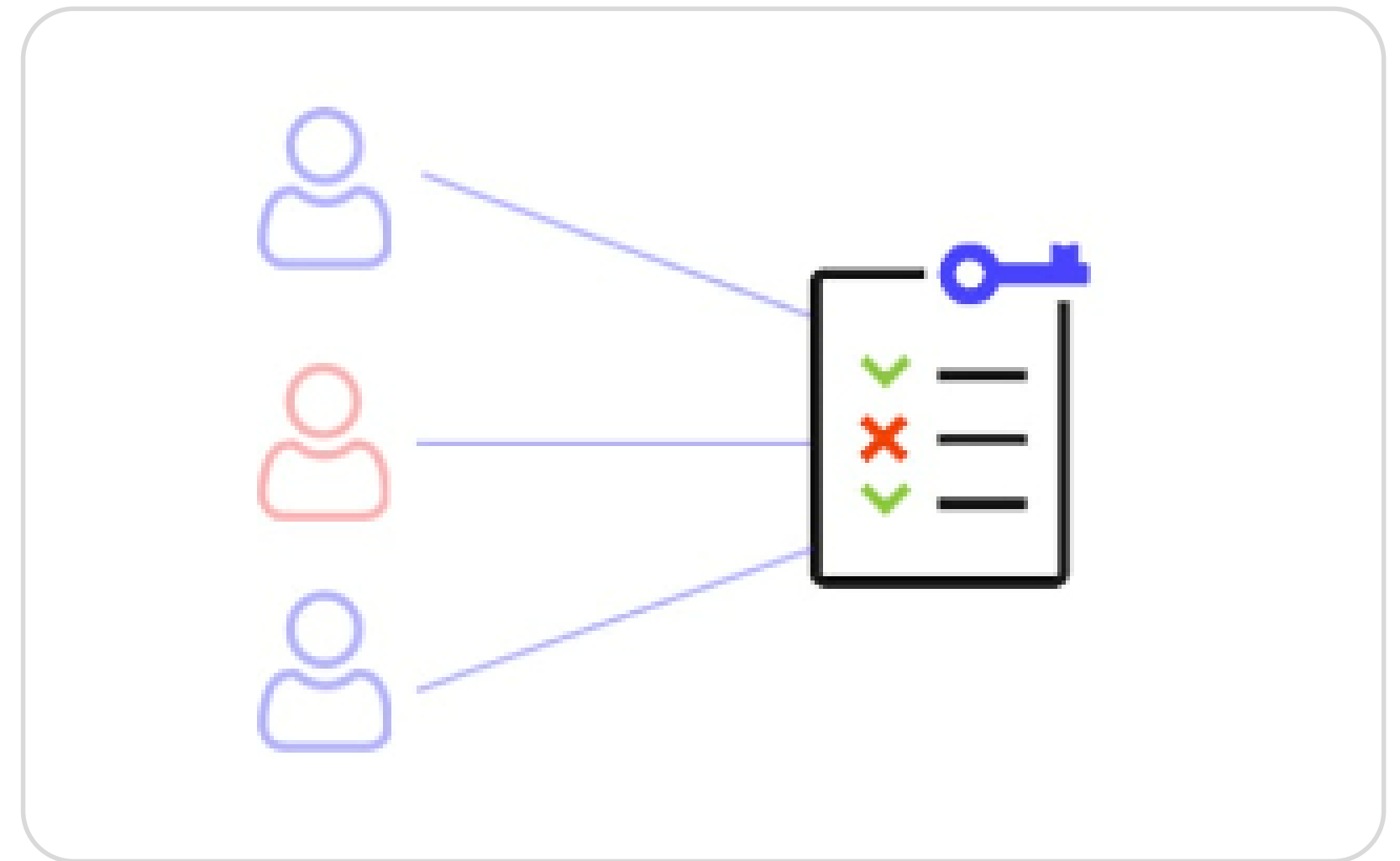
Проводите расследование при появлении других файлов с такими привилегиями.



Изображение: [Discretionary Access Control \(DAC\)](#)

Ограничение доступа с помощью Access Control List (ACL)

- Создайте список управления доступом (ACL) для пользователей или группы
- Создайте унаследованный ACL для каталога
- Используйте параметр `tar --acls` для предотвращения потери списков ACL во время резервного копирования
- Создайте группы пользователей и добавьте в неё участников
- Создайте общий каталог для группы и установите для него соответствующие разрешения
- Установите бит SGID и «липкий» бит в общем каталоге
- Используйте списки ACL для разрешения доступа к файлу в группе только определённым членам группы в общем каталоге



Изображение: [Access Control List \(ACL\)](#)

Ограничение и контроль доступа с помощью SELinux и/или AppArmor

Установить контексты безопасности для файлов и каталогов.
Использовать SELinux и создать политику для него и/или
использовать AppArmor и создать политику для него.

В SELinux определяются роли и доступ пользователей.
Надёжный, тонко настраивается.

Apparmor привязывает атрибуты контроля к программам.
Проще настраивается, но обладает не всем
функционалом SELinux.

Включение аудита

В Linux логируется почти всё — от событий ядра до пользовательских действий. В папке `/var/log` находятся логи операционной системы, демонов, утилит и приложений.

С помощью аудита реализуют журналирование для событий:

- доступ к объектам файловой системы
- выполнение системных вызовов
- запуск пользовательских команд
- логины пользователей
- действия с учётными записями и привилегиями

Удобный инструмент для настройки аудита — утилита `auditd`



Изображение: [Linux](#)

Защитите паролем загрузчик GRUB 2

Доступ к загрузке — всё равно, что доступ к паролю root.

Любой, кто может получить доступ к загрузчику, также может легко получить доступ к правам root в вашей системе.

Поэтому необходимо ставить пароль на загрузчик ОС.

Установите обновления

- Пакеты устаревают
- В некоторых находят критичные уязвимости.
- Если вы используете уязвимые компоненты, то всё становится бессмысленно

Важная задача администратора: регулярно поддерживать сервисы в актуальном состоянии и вовремя устанавливать обновления.



Изображение: [Odoo Upgrade Service](#)

Проверка системы на соответствие безопасности

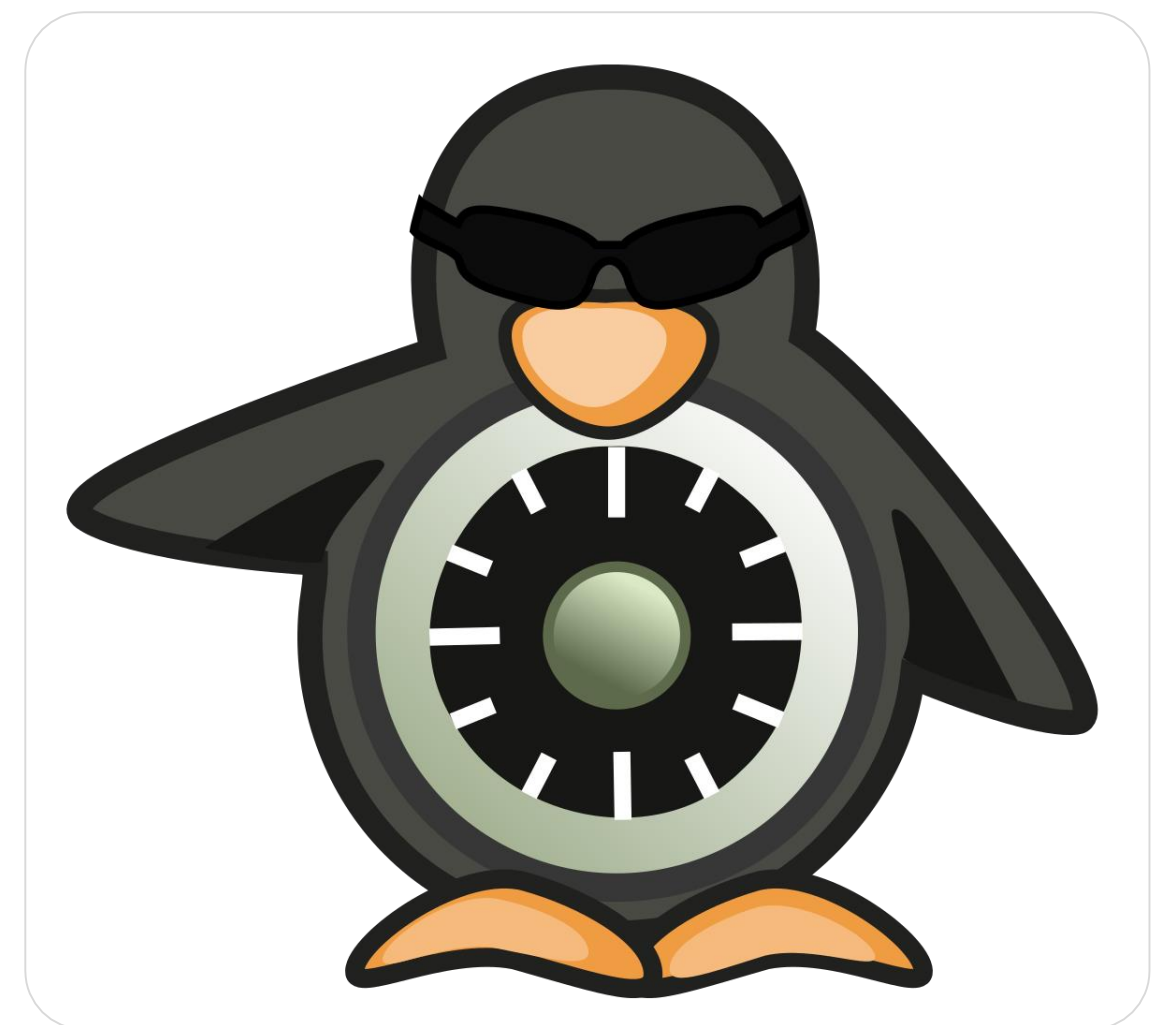
Использование OpenSCAP или LinPeas.

Проверка сканерами уязвимости.

Никогда не устанавливайте на сервер ничего, что вам абсолютно не нужно. Отключите ненужные сетевые службы.

Проверьте запущенные службы командой:

```
sudo systemctl -t service --state=active  
netstat -lp -A inet
```



Изображение: [SELinux](#)

Выводы

В этом видео вы узнали:

- для чего необходимо производить настройки безопасности
- что необходимо настроить, чтобы избежать взлома
- как работают встроенные механизмы защиты Linux